VULNERABILITY ASSESSMENT REPORT

Target: testphp.vulnweb.com
Assessment Type: Passive Security Review
Prepared By: S. Keerthana
Date: 15 – 02 – 2026

Contents

Scope Of Assessment 1
Tools Used 2
Risk Summary 2
Detailed Findings 3
Finding 1: Absence of Anti-CSRF Tokens 3
Finding 2: Content Security Policy (CSP) Header Not Set 3
Finding 3: Missing Anti-Clickjacking Header 4
Finding 4: Server Information Disclosure 4
Finding 5: X-Content-Type-Options Header Missing 5
Finding 6: Charset Mismatch 5
Finding 7: Modern Web Application (Informational) 5
Exposure Analysis (Nmap) 6
Remediation Roadmap 6
Conclusion 7

EXECUTIVE SUMMARY

A passive vulnerability assessment was conducted on the publicly accessible web application testphp.vulnweb.com. The objective of this assessment was to identify common security weaknesses using non-intrusive techniques within a strictly read-only scope.No exploitation attempts, brute-force attacks, or active scanning methods were used.The assessment identified several configuration-related security weaknesses, primarily involving missing HTTP security headers and absence of CSRF protection mechanisms. No critical (high-risk) vulnerabilities were detected during this evaluation.While these findings do not indicate immediate compromise risk, they may increase exposure to common web-based attacks such as Cross-Site Scripting (XSS), Clickjacking, and Cross-Site Request Forgery (CSRF).Addressing the identified issues will significantly improve the application's overall security posture.

SCOPE OF ASSESSMENT

Included:

- Public-facing pages only
- Passive scanning techniques

- Header inspection
- Cookie inspection
- Service exposure analysis

Excluded:

- Login bypass attempts
- Exploitation
- Brute force attacks
- Denial-of-Service testing
- Database testing

This assessment followed ethical and non-destructive security practices.

TOOLS USED

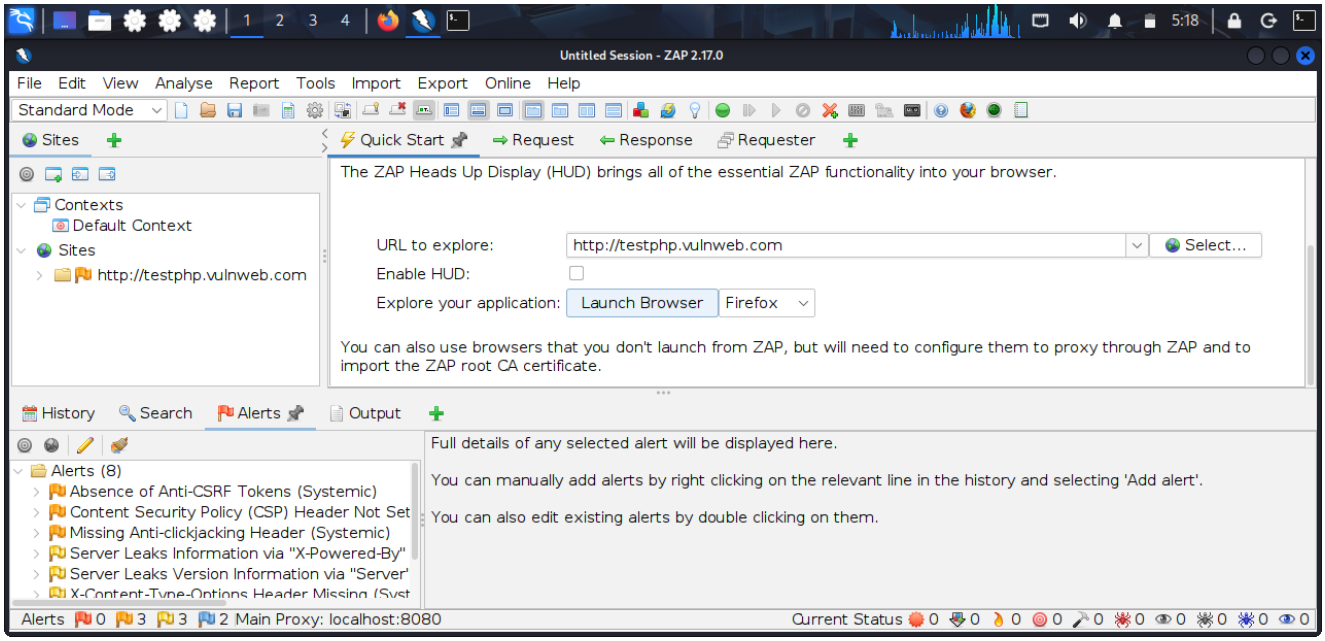
- Nmap – Service and port exposure analysis
- OWASP ZAP (Passive Scan Only) – Vulnerability identification
- Browser Developer Tools – Header and cookie inspection

RISK SUMMARY

Risk Level	Count
High	0
Medium	3
Low	3
Informational	2

No high-severity vulnerabilities were identified.

DETAILED FINDINGS



Finding 1: Absence of Anti-CSRF Tokens

Risk Level: Medium

Description

Forms within the application do not implement Anti-CSRF tokens.

Impact

Attackers may trick authenticated users into performing unintended actions without their knowledge.

Recommendation

Implement CSRF tokens in all state-changing forms and validate them server-side.

Finding 2: Content Security Policy (CSP) Header Not Set

Risk Level: Medium

Description

The HTTP response does not include a Content-Security-Policy header.

Impact

Without CSP, the application is more vulnerable to Cross-Site Scripting (XSS) attacks.

Recommendation

Implement a CSP header restricting allowed sources.

Example:

Content-Security-Policy: default-src 'self';

Finding 3: Missing Anti-Clickjacking Header

Risk Level: Medium

Description

The X-Frame-Options header is not configured.

Impact

Attackers may embed the site in a malicious iframe, enabling clickjacking attacks.

Recommendation

Add:

X-Frame-Options: DENY

or implement frame-ancestors directive in CSP.

Finding 4: Server Information Disclosure

Risk Level: Low to Medium

Description

The server discloses backend technology details via HTTP headers (e.g., Server, X-Powered-By).

Impact

Revealing server technologies assists attackers in identifying potential exploit paths.

Recommendation

Disable version disclosure in server configuration.

Finding 5: X-Content-Type-Options Header Missing

Risk Level: Low

Description

The X-Content-Type-Options header is not set.

Impact

Browsers may perform MIME type sniffing, increasing risk of content injection attacks.

Recommendation

Add:

X-Content-Type-Options: nosniff

Finding 6: Charset Mismatch

Risk Level: Low

Description

Mismatch between charset defined in HTTP headers and HTML document.

Impact

May cause inconsistent content rendering; minimal security impact.

Recommendation

Ensure consistent charset definition (UTF-8 recommended).

Finding 7: Modern Web Application (Informational)

Risk Level: Informational

Description

The application uses modern web technologies.

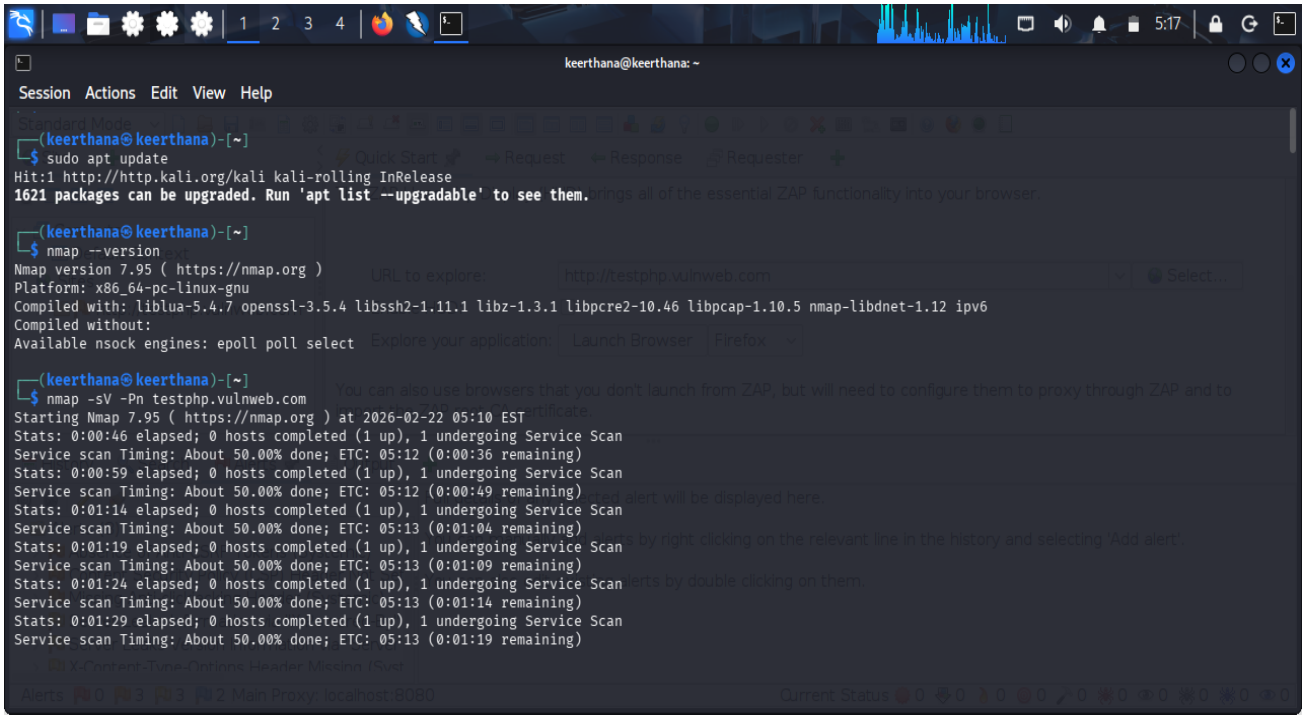
Impact

No direct security risk.

Recommendation

No action required.

EXPOSURE ANALYSIS (NMAP)



A service exposure scan was performed using:

nmap -sV -Pn testphp.vulnweb.com
Observations:

- HTTP service exposed on Port 80
- Server version information visible

No unnecessary high-risk ports were identified.

REMEDIATION ROADMAP

Immediate (Medium Priority)

- Implement CSRF protection
- Configure Content Security Policy
- Enable Anti-Clickjacking header

Short-Term (Low Priority)

- Disable server version disclosure
- Add X-Content-Type-Options
- Fix charset mismatch

Long-Term

- Conduct periodic security reviews
- Implement secure configuration baselines
- Consider automated security monitoring

CONCLUSION

The assessment identified configuration-level security gaps that increase exposure to common web attacks. No critical vulnerabilities were observed within the defined passive scope.

Implementing the recommended improvements will enhance the application's resilience against web-based threats and strengthen its overall security posture.